

Elpako programinės įrangos ir epaslaugos.lt prisijungimo su ATK problema

Autorius: Tadas Sasnauskas tadas@yoyo.lt

2026-04-20

Įvadas

Dokumentas apibūdina Elpako programinės įrangos saugumo trūkumą. Pasirašant prisijungimo duomenis su asmens tapatybės kortele juose nėra įtrauktas konkretus parašo panaudojimo tikslas. Tuo pačiu tikslas nėra aiškiai komunikuojamas vartotojui. Ko pasekoje yra galimybė kurti apgaulingas interneto svetaines, prie kurių besijungiantis vartotojas gali to nežinodamas programišiams suteikti prieigą prie epaslaugos.lt ir pan svetainių paskyrų.

Programinės įrangos versija

Apibūdinta problema egzistuoja Elpako 3.2.1 versijoje.

Techinės detalės

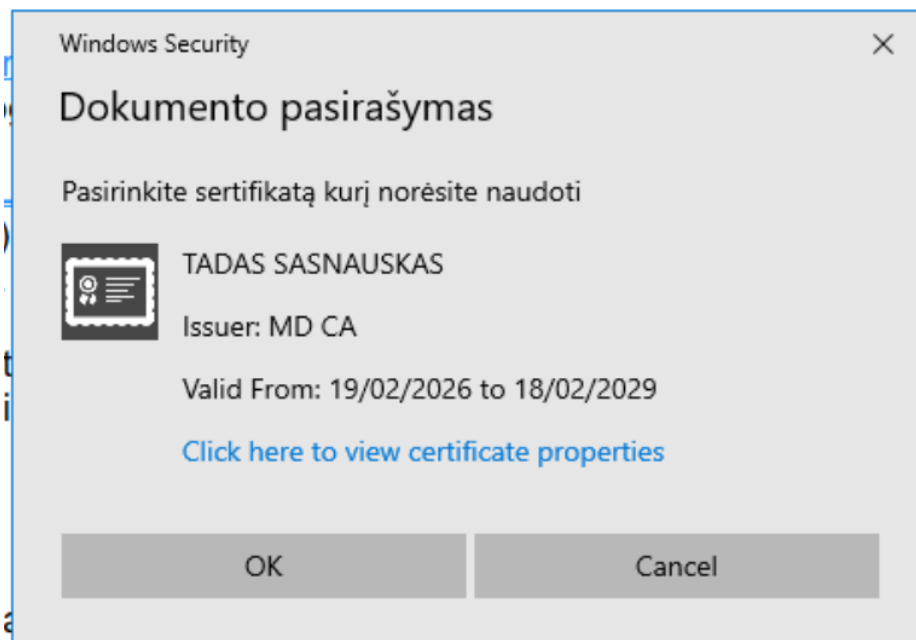
Problemos centre - **Elpako Local API**.

Dokumentacija: <https://documenter.getpostman.com/view/11918038/UVJihuNs#9aa7e102-186c-4ed1-a8e7-7c3ff2be4924>

Pirmiausia reik pastebėti, kad Local API nei riboja prieigą su *Cross-Origin Resource Sharing (CORS)* metodais, nei panaudoja CORS pateikiamą informaciją validuoti parašo užklauskos kilmę.

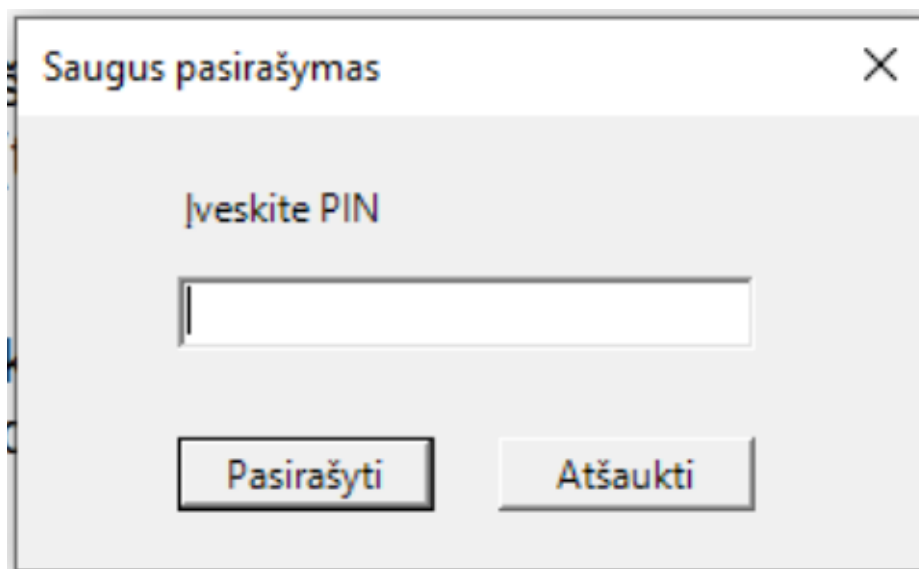
Užklausa `https://127.0.0.1:38888/Signing/Sign` leidžia pasirašyti informacinį žetoną (token) parametre `dbts`.

Pasirašymo metu vartotojui yra parodomas sertifikato pasirinkimo langas:



sertifikato langas

Po kurio seka PIN langas:



pin langas

Nei sertifikato, nei PIN langas nenurodo parašo tikslo/paskirties, užklauskos kilmės.

Tai leidžia kurti piktavališkas svetaines su ATK prisijungimu, kuriose Local API užklauso iš vartotojo naršyklės yra persiunčiamos į programišiaus kompiuterį ir naršyklę. Ko pasekoje, vartotojui jungiantis prie tos piktavališkos svetainės, programišius gali persiųsti epaslaugos.lt prisijungimo metu išduotą dbts žetoną į vartotojo naršyklę, gauti parašą ir parsisiųsti į savo kompiuterį. Parašas tada panaudojamas prisijungti prie epaslaugos.lt ir kitų svetainių naudojančių Elpako autentifikacijos metodus.

Demonstracija

Demonstracijos įrašas: <https://www.youtube.com/watch?v=GmUVmRDaARk>

Trumpa demonstracija be komentarų: <https://www.youtube.com/watch?v=pRRGTAn5ESE>